

LEARNING RESOURCE GUIDE

ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional Participant Workbook

Learning Objectives

By the end of this lecture and its accompanying guide, you will be able to:

- By the end of this guide, you will be able to explain file storage's use case and security considerations relative to object and block storage.
- By the end of this guide, you will be able to describe how software-defined networking transforms network configuration from a physical to a programmatic process.
- By the end of this guide, you will be able to explain the role of a Virtual Private Cloud as the primary vehicle for network-level security control in cloud environments.
- By the end of this guide, you will be able to distinguish security groups from network access control lists and apply each correctly in a VPC design.
- By the end of this guide, you will be able to correct the misconception that customers have no meaningful control over cloud network configuration.
- By the end of this guide, you will be able to explain how CSPM and CWPP tooling depend on the programmatic, software-defined nature of cloud infrastructure.

Introduction

This lecture completes the building block technologies discussion by covering file storage and cloud networking, and it explicitly connects all three building blocks — virtualization, storage, and networking — to the security tooling categories that depend on them. The central theme is that cloud infrastructure is defined and reconfigured through software rather than physical hardware changes, and this programmability is what makes both rapid attacker impact and rapid automated defense possible.

File storage rounds out the three cloud storage architectures alongside object and block storage, providing a shared file system that multiple virtual machines can mount concurrently — the cloud equivalent of a traditional network-attached storage share.

The networking discussion centers on the Virtual Private Cloud, or VPC, which is the logically isolated network segment a customer provisions and controls within a public cloud environment. Understanding the VPC, along with security groups and network access control lists, is essential because network-level controls remain substantially the customer's responsibility even though the underlying physical network belongs to the provider — a point that is frequently misunderstood and frequently tested.

Core Concepts Explained

File Storage

Definition: A cloud storage architecture that provides a shared file system mountable simultaneously by multiple virtual machines, analogous to traditional network-attached storage, exemplified by Amazon Elastic File System (EFS) and Azure Files.

Business relevance: File storage enables workloads requiring concurrent shared access — content management systems, shared development environments, and legacy applications migrated to the cloud that expect a traditional file system interface.

Cloud Security Practitioner relevance: As a Cloud Security Practitioner, you apply network-level access controls restricting which systems can mount the file system, encryption in transit and at rest, and identity-based read/write permissions at the file and directory level.

Real-world example: A media company migrated its content management system to the cloud and needed multiple application servers to read and write to the same media asset library concurrently. The team provisioned Amazon EFS and initially mounted it with default network settings, allowing any instance within the VPC to mount the file system regardless of role. A security review later found that a compromised low-privilege web server instance could mount and read the entire content library, including unpublished material, because mount-level access had not been restricted to only the specific instances that needed it. The fix: apply security-group-based mount targets restricting EFS access to only the application tier that legitimately needs it, combined with IAM-based access points enforcing directory-level permissions per application role.

Risks or limitations: Overly broad mount-level access to shared file storage allows any compromised instance within the network scope to read or write shared data regardless of its actual role; the practice that prevents this is restricting mount targets by security group to only the instances that need access, combined with identity-based access points for directory-level permission enforcement.

Virtual Private Cloud (VPC)

Definition: A logically isolated network within a public cloud environment that the customer provisions and controls, defining IP address ranges, subnet structure, routing tables, and security rules, even though the underlying physical infrastructure is shared with other tenants.

Business relevance: The VPC is the cloud equivalent of an organization's private network and is the foundation on which nearly all other network security architecture — segmentation, peering, hybrid connectivity — is built.

Cloud Security Practitioner relevance: As a Cloud Security Practitioner, the VPC is your primary unit of network-level security design: subnet segmentation, routing control, and security rule definition all happen at this layer.

Real-world example: A healthcare SaaS company designed its VPC with public-facing web servers in one subnet, application servers in a private subnet with no direct internet route, and database servers in an even more restricted private subnet reachable only from the application tier. This three-tier subnet segmentation, enforced through VPC routing tables and security groups, meant that even if an attacker compromised a public-facing web server, they could not directly reach the database tier without also compromising the application tier first — a defense-in-depth pattern directly enabled by VPC-level network segmentation. This design was later cited favorably in the company's SOC 2 audit as evidence of appropriate network segmentation controls.

Risks or limitations: A flat VPC design with no subnet segmentation means a single compromised instance has direct network reach to every other resource in the environment; the practice that prevents this is designing

tiered subnets (public, private-application, private-data) with routing tables and security groups enforcing that traffic can only flow through the intended tiers.

Security Groups vs. Network Access Control Lists (NACLs)

Definition: Security groups are stateful virtual firewalls attached directly to cloud resources (instance-level), controlling inbound and outbound traffic by protocol, port, and source/destination; NACLs are stateless filtering rules applied at the subnet boundary, evaluated in numbered order.

Business relevance: Using both layers together provides defense in depth: a misconfigured security group rule can be caught by a correctly configured NACL, and vice versa, reducing the chance that a single configuration error fully exposes a resource.

Cloud Security Practitioner relevance: As a Cloud Security Practitioner, you design layered network filtering using both mechanisms — security groups for fine-grained, resource-level control and NACLs for coarser, subnet-wide guardrails — rather than relying on either mechanism alone.

Real-world example: During an incident response exercise, a security team discovered that a database server's security group had been misconfigured to allow inbound traffic from 0.0.0.0/0 (any source) on the database port, due to a copy-paste error during a rushed deployment. Because the subnet's NACL was correctly configured to only allow traffic from the application-tier subnet's IP range, the overly permissive security group rule was effectively neutralized — the NACL blocked the traffic before it could reach the instance. This real-world save became the organization's justification for mandating NACL configuration as a required second layer on every subnet containing sensitive resources, not an optional hardening step.

Risks or limitations: Relying on security groups alone, with no NACL layer, means a single misconfigured security group rule can fully expose a resource with no compensating control; the practice that prevents this is mandating NACL configuration at the subnet boundary as a required defense-in-depth layer alongside security groups, not an optional extra.

Practical Applications

The VPC, security groups, and NACLs together form the practical toolkit a cloud security practitioner uses daily to design and audit network segmentation.

Designing Tiered Subnet Segmentation for a New Workload

When architecting network segmentation for a new customer-facing application, a cloud security architect places public-facing components in a public subnet with a route to an internet gateway, application logic in a private subnet reachable only from the public subnet's load balancer, and data stores in a further-restricted private subnet reachable only from the application tier. The embedded best practice: no subnet should have a broader network reach than its function strictly requires, and this should be verified explicitly during design review, not assumed from provider defaults.

Auditing Security Group Rules for Overly Permissive Access

A cloud security engineer runs a quarterly audit of all security group rules across the environment, specifically flagging any rule that allows inbound traffic from 0.0.0.0/0 on a sensitive port (database ports, SSH, RDP) for manual justification or remediation. The specific best-practice decision rule: any 0.0.0.0/0 inbound rule on a non-public-facing resource requires documented business justification and a compensating NACL control, or it is remediated within the audit cycle.

Correcting Vendor and Stakeholder Misconceptions About Cloud Network Control

When briefing business stakeholders who assume the cloud provider handles all network security because the infrastructure is 'in the cloud,' a cloud security practitioner explains the shared responsibility boundary explicitly: the provider secures the physical network, but VPC routing, security group policy, NACL configuration, and VPN or dedicated-circuit connectivity to on-premises networks are the customer's responsibility. The best practice embedded here: document and present the network-layer shared responsibility split explicitly in every new cloud project's security design review, so the customer-side network security obligations are never assumed away.

Best Practices

- **Restrict file storage mount targets to only the instances that need access.** Use security-group-based mount target restrictions and identity-based access points to enforce that shared file systems are reachable only by the specific application tier that legitimately requires them.
- **Design VPCs with tiered subnet segmentation, never a flat network.** Separate public-facing, application, and data tiers into distinct subnets with routing tables and security groups enforcing that traffic can only flow through the intended path between tiers.
- **Mandate NACLs as a required second layer of network filtering, not an optional extra.** Configure subnet-level NACLs alongside instance-level security groups on every subnet containing sensitive resources, so a single misconfigured security group rule does not fully expose a resource.
- **Audit security group rules quarterly for overly permissive 0.0.0.0/0 inbound access.** Flag any inbound rule allowing traffic from any source on a sensitive port for mandatory business justification or remediation within the audit cycle.
- **Document the network-layer shared responsibility split explicitly for every new cloud project.** Present which network security obligations belong to the customer (VPC design, security groups, NACLs, VPN/dedicated connectivity) versus the provider (physical network) during every project's security design review.

Common Mistakes and Misconceptions

Misconception: Mounting shared file storage with default settings that allow any instance in the VPC to access it.

Correct approach: Restrict mount targets by security group to only the specific application tier that needs access, combined with identity-based directory-level permissions.

Misconception: Designing a flat VPC with no subnet segmentation between public, application, and data tiers.

Correct approach: Design tiered subnets with routing tables and security groups that enforce traffic can only flow through the intended path, limiting the blast radius of any single compromised instance.

Misconception: Relying on security groups alone with no NACL layer configured.

Correct approach: Configure NACLs at the subnet boundary as a mandatory defense-in-depth layer, so a misconfigured security group rule has a compensating control.

Misconception: Assuming the cloud provider is responsible for all network security because the infrastructure is 'in the cloud.'

Correct approach: Explicitly document and communicate that VPC design, security group policy, and NACL configuration are customer responsibilities under the shared responsibility model.

table: Security Group vs. NACL Decision Matrix

Use this matrix when deciding which network filtering mechanism to apply for a given control requirement.

Requirement	Use Security Group	Use NACL
Fine-grained, resource-specific traffic control	Yes — stateful, attached directly to the resource	No — too coarse for per-resource rules
Subnet-wide guardrail / defense-in-depth backstop	No — does not apply at subnet level	Yes — stateless, applied at subnet boundary
Explicit deny rules	No — security groups are allow-only	Yes — NACLs support explicit deny rules

How to use this: Use both mechanisms together: security groups for resource-level precision, NACLs for subnet-level defense-in-depth, never one in place of the other for sensitive resources.

Knowledge Check

Test your understanding before moving on. Answers are shown below each question.

Q1. A content management platform requires multiple virtual machines to read and write to the same shared media library concurrently. Which cloud storage type is most appropriate?

- A) A. Block storage
- B) B. Object storage
- C) C. File storage
- D) D. Ephemeral storage

Answer: C. File storage

Q2. A security review finds a database server's security group allows inbound traffic from 0.0.0.0/0 on the database port due to a configuration error, but the subnet's NACL correctly restricts traffic to the application-tier subnet's IP range. What was the practical security outcome?

- A) A. The resource was fully exposed because security groups override NACLs
- B) B. The NACL neutralized the overly permissive security group rule, demonstrating defense-in-depth
- C) C. Both controls failed simultaneously, exposing the database
- D) D. NACLs do not apply to database servers

Answer: B. The NACL neutralized the overly permissive security group rule, demonstrating defense-in-depth

Q3. A business stakeholder assumes the cloud provider is fully responsible for network security because the infrastructure is 'in the cloud.' What is the most accurate correction a cloud security practitioner should provide?

- A) A. The stakeholder is correct; customers have no network security responsibilities in the cloud
- B) B. The provider secures the physical network, but VPC design, security groups, NACLs, and connectivity configuration remain the customer's responsibility
- C) C. Network security is entirely the customer's responsibility with no provider involvement
- D) D. Network responsibilities depend solely on which programming language the application uses

Answer: B. The provider secures the physical network, but VPC design, security groups, NACLs, and connectivity configuration remain the customer's responsibility

Reflection Questions

1. Does your organization's shared file storage restrict mount access by role, or is it open to any instance in the network?
2. How is your VPC currently segmented — does it follow a tiered public/application/data subnet design, or is it closer to a flat network?
3. Are NACLs configured on every subnet containing sensitive resources in your environment, or only security groups?
4. When was the last time your organization audited security group rules for overly permissive 0.0.0.0/0 inbound access?
5. How would you explain the network-layer shared responsibility split to a non-technical stakeholder in under two minutes?

Key Takeaways

- File storage provides a shared, concurrently mountable file system, distinct from the single-instance model of block storage and the API-based model of object storage.
- The Virtual Private Cloud is the primary vehicle for network-level security control in cloud environments and should be designed with tiered subnet segmentation.
- Security groups (stateful, resource-level) and NACLs (stateless, subnet-level) should be used together for defense-in-depth, never relying on either alone.
- Cloud customers retain substantial and meaningful control over network configuration — VPC routing, security groups, NACLs, and hybrid connectivity are all customer-managed.
- Software-defined networking enables both rapid legitimate reconfiguration and rapid security tooling response, since the entire network configuration is exposed through programmable APIs.
- CSPM and CWPP tooling depend directly on the programmatic nature of cloud infrastructure across the virtualization, storage, and networking layers to provide continuous automated monitoring.
- Real-world breaches involving overly permissive security groups are frequently caught (or missed) based on whether a compensating NACL control was in place.

Recommended Next Actions

Put this lecture to work within the next seven days:

6. Review your organization's file storage mount target configuration this week to confirm access is restricted to only the instances that need it.
7. Map your current VPC subnet design against the tiered public/application/data segmentation pattern and identify any gaps.
8. Confirm NACLs are configured on every subnet containing sensitive resources, not just security groups.
9. Run a security group audit this week for any 0.0.0.0/0 inbound rules on sensitive ports and document justification or remediate.